Decision Record DR-2026-028: Compliance security profile

Document control	
Document ID	DR-2026-028
Document type	Decision Record
Date	2026-04-21
Status	Accepted
Meeting	TRBM-2026-04-21
Review IDs	TRB-2026-028
Feature keys	Compliance security profile@Security & Networking
Classification	Internal – Synthetic Sample

> Acme Health Plan is fictional. This is a synthetic sample document for the Databricks Feature Tracker.

Status: Approved · **Approved scope:** PHI · **Decided at:** TRBM-2026-04-21
Review: TRB-2026-028 · **Feature:** `Compliance security profile@Security & Networking` · **Databricks phase at decision:** GA

Context

Information Security presented the Compliance Security Profile (CSP) as the master switch for HIPAA/PCI/FedRAMP posture. TRB reviewed hardened images, audit requirements, and permanent enablement.

Decision

The Compliance Security Profile is approved and required for all PHI workloads. Once enabled on a workspace, it cannot be disabled. All production PHI workspaces must have CSP enabled.

Risks considered

- Permanent CSP flag blocks certain features
- Image updates may have performance impact
- Audit logging volume increases cost

Mitigations relied on

- CSP feature matrix documented (limits known upfront)
- Performance impact quantified (<5% CPU overhead)
- Audit sampling tuned to balance cost vs. visibility

Control mappings

- HIPAA-Security-Rule 164.308(a)(1)(i) (Security management process): Satisfied
- NIST-800-53-R5 CM-6 (Configuration Settings): Satisfied
- HITRUST-CSF 09.a (System Development and Maintenance): Satisfied

Re-review

Trigger: Annual re-review · Next review: 2027-04-21